febbraio 2024

1. Public Key Cryptography

(a) The following diagram describes (a simplified account of) the establishment of a SSL/-TLS session between a web browser B and a web server W, where K_W is the public key of W and H is a cryptographic hash function. Please add the missing elements in the messages by filling in the blanks.

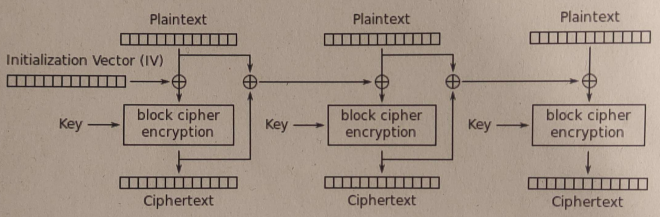
1. $B \rightarrow W : HELLO$
2. $B \leftarrow W : W, K_W, E(\underline{K_W^{-1}}, H([W, K_W]))$
3. $B \rightarrow W : E(\underline{K_W}, K)$

(b) Let D_1, D_2, D_3 be the data received by the web browser B in step 2 of the protocol. Which of the following checks must be carried out by B before sending to W the message at step 3?

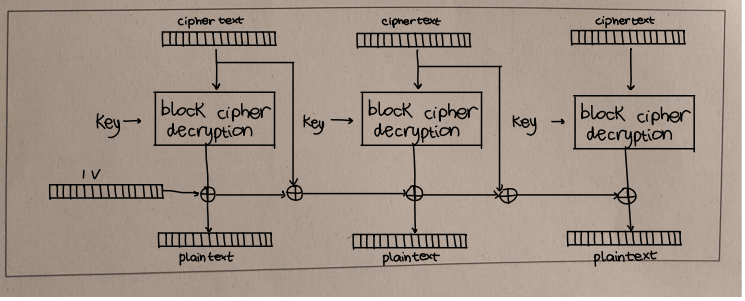
A. Decrypt D_3 with $\underline{D_2}$, compute $H(D_1, \underline{D_2})$ and check that the two operations yield the same result.

2. Symmetric Cryptography

Consider the following mode of operation used for encryption.



Draw the correspoding schema to be used for decryption.



3. Security Protocols

Consider the following authentication protocol

1. $A \rightarrow B : A$
2. $B \rightarrow A : B, N_B$
3. $A \rightarrow B : E(K, [A, B, N_B])$

where K is a key shared between A and B, N_B is a nonce generated by B and $E(K, M) = K \oplus M$. (We thus assume that the length of the key K is equal to length of the bitstring obtained by concatenating the bitstrings representing A, B, and N_B.)

(a) The protocol is used by B to authenticate A. Does the protocol achieve this goal? Please justify your answer.

No. In caso di attacco Man-In-The-Middle, l'attaccante può origliare i messaggi e decriptare il messaggio trovando la K condivisa tramite l'operazione $K \oplus [A,B,N_B] \oplus A,B,N_B$. In quel modo può sostituire l'identificativo di A e mandare il messaggio a B.

(b) Now consider the protocol consisting of the following single step:

1. $A \rightarrow B : E(K, [A, B, T_A])$

where K is a key shared between A and B, T_A is a time-stamp generated by A, and $E(K, M) = K \oplus M$. (As above, we thus assume that the length of the key K is equal to length of the bitstring obtained by concatenating the bitstrings representing A, B, and T_A.) Upon reception of the message B must check that $T_A - T_0 < \epsilon$ where T_0 is the current value of its own clock and ϵ is a threshold that depends on the latency of the communication link. Similarly to the protocol in the previous question, this protocol is used by B to authenticate A. Does the protocol achieve this goal?

Please justify your answer.

Il protocollo può raggiungere l'obbiettivo se i due orologi sono sincronizzati e se ϵ è sufficientemente piccola.
Se C conoscesse gli identificativi di A e B, e ϵ fosse sufficientemente alta, potrebbe eseguire un attacco Man-In-The-Middle

4. Access Control

Consider the Bell-LaPadula security model. Indicate the permissions granted to a user with the following "security clearances" on a resource with security label (secret, {red, blue}):

1. (top secret, {red, blue}): lettura
2. (secret, {red}): scrittura
3. (secret, {red, black}): nessun permesso
4. (secret, {red, blue}): lettura e scrittura
5. (confidential, {red, blue}): scrittura
6. (confidential, {blue}): scrittura
7. (top secret, {red, green, blue, black}): lettura